Group 8

TEE Interface Attack Simulation Project

Sebastian Alfonso

Daniel Martínez Teruel

Alejandro Montellano

Cybersecurity for embedded systems

2025

Content

1. Trusted application and host application design.
2. Vulnerabilities.
3. Attacks.
4. Demo application

Host Application Design.

- Encrypt: ta_secret –e
    1. password_validation(pwd)
    2. updateLog("Encrypting")
    3. encrypt_file(file, key)

- Decrypt: ta_secret -d
    1. password_validation(pwd)
    2. updateLog("Decrypting")
    3. decrypt_file(file, key)

- Access log: ta_secret -a
    1. password_validation(pwd)
    2. updateLog("Decrypting")
    3. getLog(file, key)

Trusted Application Design.

- Light cryptography.
  - alloc_resources(session, param_types, params)
  - set_aes_key(session, param_types, params)
  - reset_aes_iv(session, param_types, params)
  - cipher_buffer(session, param_types, params)
- Password validation.
  - password_validation(param_types, params)
- Secret management.
  - updateLog(param_types, params)
  - get_log_entry(param_types, params)

Vulnerabilities

TEE_Result updateLog()

This function is responsible for updating a log that contains only 10 entries and is stored in a persistent object. The function does not perform any synchronization to handle the object in case of multiple instantiations of the same TA, which can lead to race conditions.

```
uint32_t flags =    TEE_DATA_FLAG_ACCESS_READ |
                    TEE_DATA_FLAG_ACCESS_WRITE |
                    TEE_DATA_FLAG_ACCESS_WRITE_META |
                    TEE_DATA_FLAG_SHARE_READ |
                    TEE_DATA_FLAG_SHARE_WRITE;

res = TEE_OpenPersistentObject(TEE_STORAGE_PRIVATE,OBJ_ID, OBJ_ID_LEN,flags, &obj);
```

Vulnerabilities

TEE_Result get_log_entry()

This function returns a single row from the log; its input is the index into the log array. The main vulnerability lies in the input validation of the index, which should be limited to values between 0 and 9 but is only validated to be <9.

```
int32_t entry_index = params[1].value.a;
```

Vulnerabilities

TEE_Result password_validation()

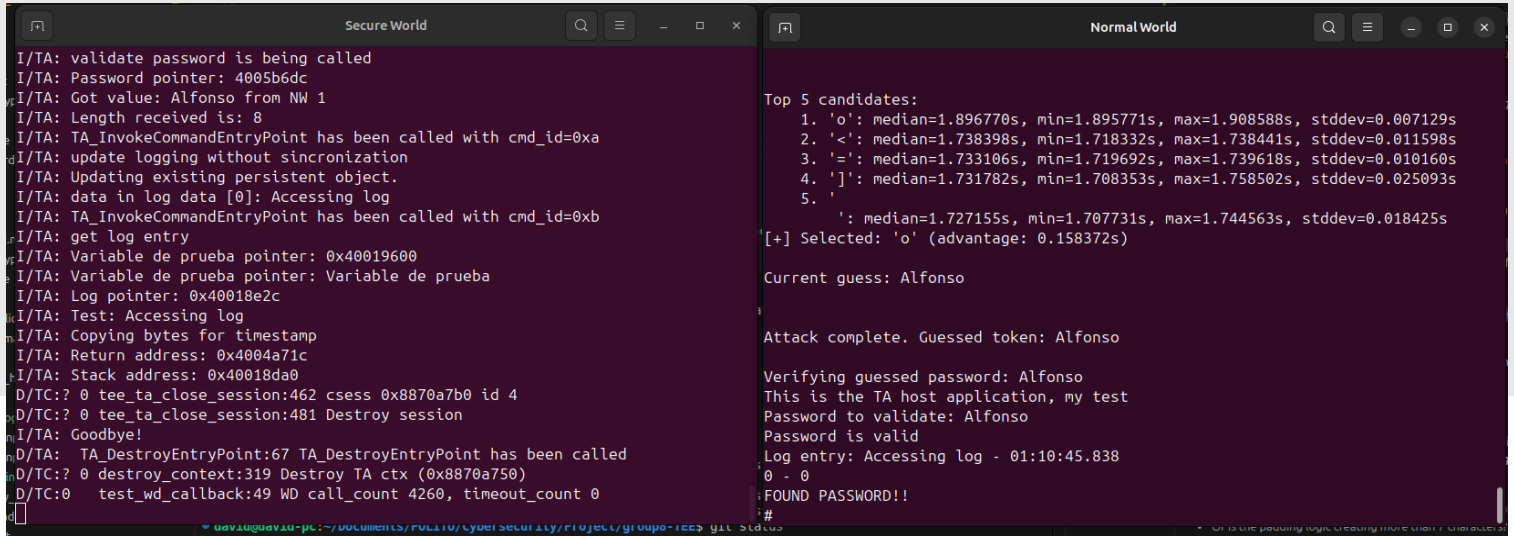
- This function simply validates the password, which is stored in a static variable.
- String validation uses strcmp, which compares characters sequentially and returns when a mismatch or the end of the string is reached.

Attacks – Timing

- The file timing.py:
  - It tests with every possible character in each position of the password
  - Based on the character that takes the longer it chooses the best fit for the position until it assembles a complete string.
- Results:
  - Timing attack was achieved in a didactical manner. It starts with a known token size as done in Lab 3.

Remarks:

- A delay had to be introduced in pass_validation.c



Attacks – Fuzzing Attack

- The file fuzzingAttack.py:
  This attack explores the effect of different inputs on the application.

  This includes:
  1. Sending fewer or more parameters than expected
  2. Using special characters in the password and encryption key
  3. Testing negative indices when accessing logs
  4. Providing extremely large numerical values
  5. The goal is to identify improper input handling that could lead to unexpected behavior or security vulnerabilities.
- Results:
  Some inputs generate segmentation fault.

Attacks - Memory Mapping

- The file memory_mapping.py:
  - It runs ta_secret -a with negative indices until it receives back an error. The received result is logged to the file memory.txt
- Results:
  - The password was retrieved on index –634
  - Other information like errors or similar – indices –756:-716

Attacks - Memory Mapping

```
Index: -728; ta_secret -a  -728 -728
Log entry: %0*d %*s %s:%d UEIDFInvalid hint %#xlib/libutee/tee_api_operations.cIS_POWER_OF_TWO(op->block_s
Index: -728; ta_secret -a  -728 -728
0
Index: -729; ta_secret -a  -729 -729
Log entry: d.property2stack smashing detected(null)%08x-%04x-%04x-%02x%02x-%02x%02x%02x%02x%02x%02x%c/%s:
Index: -729; ta_secret -a  -729 -729
0
Index: -730; ta_secret -a  -730 -730
Log entry: ectorg.linaro.optee.examples.hello_world.property1Some stringorg.linaro.optee.examples.hello_worl
Index: -730; ta_secret -a  -730 -730
0
Index: -731; ta_secret -a  -731 -731
Log entry: a.version1.0gpd.ta.descriptionExample Projectgpd.ta.endiangpd.ta.doesNotCloseHandleOnCorruptObj
Index: -731; ta_secret -a  -731 -731
0
Index: -732; ta_secret -a  -732 -732
Log entry: a.singleInstancegpd.ta.multiSessiongpd.ta.instanceKeepAlivegpd.ta.dataSizegpd.ta.stackSizegpd.t
Index: -732; ta_secret -a  -732 -732
0
Index: -733; ta_secret -a  -733 -733
password_validationgpd.t
Index: -733; ta_secret -a  -733 -733
0
Index: -734; ta_secret -a  -734 -734
Log entry: retrieve_secretParameter type mismatch!validate password is being calledPassword pointer: %xGot
Index: -734; ta_secret -a  -734 -734
0
Index: -735; ta_secret -a  -735 -735
Log entry: ruebaunsecure storingunsecure retrievingNo secret storedupdateLogG8get_log_entrystore_secret
Index: -735; ta_secret -a  -735 -735
0
Index: -736; ta_secret -a  -736 -736
Log entry: Copying bytes for timestampReturn address: %pStack address: %pOut of bounds accessVariable de p
```

```
Index: -717; ta_secret -a  -717 -717
Log entry: sizeTCB allocation failed (%zu bytes)DTV allocation failed (%zu bytes)dl_phdr_info allocation fai
Index: -717; ta_secret -a  -717 -717
0
Index: -718; ta_secret -a  -718 -718
Log entry: rsiongpd.tee.sockets.tcp.versiongpd.tee.internalCore.versionlib/libutee/tcb.ctotal_size >= _tls_
Index: -718; ta_secret -a  -718 -718
0
Index: -719; ta_secret -a  -719 -719
Log entry: onvertFromFMMTEE_BigIntComputeFMMtruefalse%u:%pUlgpd.tee.arith.maxBigIntSizegpd.tee.sockets.ve
Index: -719; ta_secret -a  -719 -719
0
Index: -720; ta_secret -a  -720 -720
Log entry: dTEE_BigIntInvModTEE_BigIntRelativePrimeTEE_BigIntExpModTEE_BigIntComputeExtendedGcdTEE_BigIntC
Index: -720; ta_secret -a  -720 -720
0
Index: -721; ta_secret -a  -721 -721
Log entry: BigIntConvertFromS32bigint_binary_modTEE_BigIntShiftRightTEE_BigIntNegTEE_BigIntDivTEE_BigIntMo
Index: -721; ta_secret -a  -721 -721
0
Index: -722; ta_secret -a  -722 -722
Log entry: get_mpibigint_binarympi_egcd_TEE_MathAPI_InitTEE_BigIntInitTEE_BigIntConvertToOctetStringTEE_
Index: -722; ta_secret -a  -722 -722
0
Index: -723; ta_secret -a  -723 -723
Log entry: lToo large bigintModulus is too shorttoo small modulus or trying to invert zerotoo small modulus
```

Attacks – Race condition

- Baseline test:
  1. It executes 9 commands serially.
  2. Check whether all command are registered in the log.
- Pushing parallel execution.
  1. It executes 9 commands in parallel.
  2. Check whether all commands are registered in the log.

DEMO

Politecnico di Torino

Thank you!

Questions?